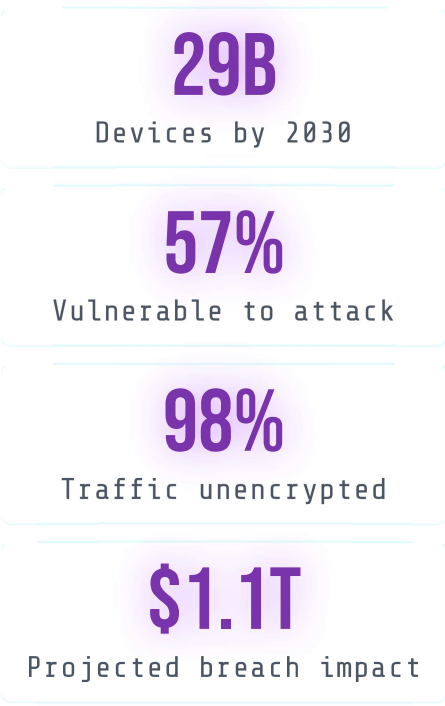
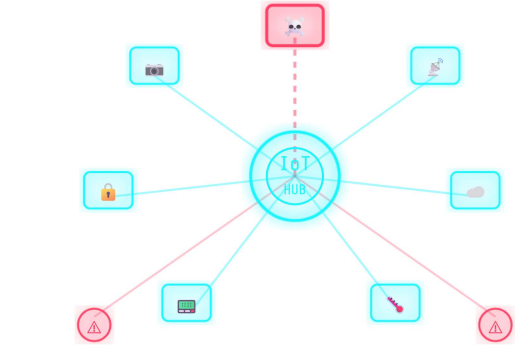


EMERGING THREATS: IOT SECURITY

A systematic analysis of Internet of Things vulnerabilities — mapped to classical security principles, with open research challenges for the academic and practitioner community.



01 – IOT THREAT LANDSCAPE

T-01

Insecure Default Credentials

- Factory passwords never changed on millions of devices
- Attackers use published credential databases
- Mirai exploited just 61 default pairs to infect 600K+ nodes

T-02

Unpatched Firmware

- No secure OTA update mechanism
- Devices deployed 10–15 years; support ends in 2–3
- Known CVEs accumulate with no mitigation

T-03

Insecure Network Services

- Exposed Telnet/SSH/HTTP with weak auth
- UPnP misconfig opens internal network access
- MQTT/CoAP protocol flaws enable interception

T-04

Lack of Encryption

- Constrained hardware forgoes TLS/DTLS
- Plaintext channels expose sensitive telemetry
- MitM attacks trivially intercept commands

T-05

Physical Tampering

- JTAG/UART debug ports expose firmware
- Power analysis leaks cryptographic keys
- Devices in uncontrolled environments at risk

T-06

Botnet Recruitment / DDoS

- Compromised devices form massive botnets
- Attacks exceeding 1 Tbps (Mirai, Mozi)
- Targeting CDNs, DNS, critical infrastructure

02 – CLASSICAL SECURITY PRINCIPLES

THREAT	PRINCIPLES
Default credentials	C, I
Unpatched firmware	I, A
Insecure services	C, Auth
No encryption	C, I
Physical tampering	I, Auth
Botnet/DDoS	A

ATTACK SURFACE LAYERS

Device	Firmware	Network	Cloud	App	User
HARDWARE 🔧 PHYSICAL Debug ports (JTAG/UART), chip cloning, cold-boot memory attacks	FIRMWARE 📀 SOFTWARE Hardcoded secrets, buffer overflows, unsigned OTA updates	PROTOCOL 📡 NETWORK MQTT hijack, Zigbee/Z-Wave replay, BLE relay, CoAP amplification	BACKEND ☁️ CLOUD API Broken auth, IDOR, mass account takeover, API key exposure		

🦴 CASE STUDY: MIRAI BOTNET ATTACK (2016)

The largest DDoS attack in history – powered entirely by IoT devices





03 – OPEN RESEARCH CHALLENGES

01



Lightweight Cryptography

- Encryption for devices with **<4KB RAM**
- NIST LWC finalist: **ASCON** scheme
- Formal verification across heterogeneous MCU families

02



Automated Vulnerability Discovery

- **Firmware fuzzing** without hardware-in-the-loop
- Static analysis of **closed-source binaries**
- Scalable RTOS and radio stack analysis tools

03



Secure Device Identity

- PKI for **billions of constrained endpoints**
- **Zero-touch provisioning** without central trust anchors
- Certificate revocation at IoT scale

04



AI-Based Anomaly Detection

- **Federated learning** without centralising telemetry
- Balance detection latency vs. **energy budget**
- Low false-positive rate on resource-constrained nodes

05



Secure OTA Updates

- Authenticated delivery to **intermittent devices**
- **Rollback protection** and delta patching
- Post-quantum cryptographic agility paths

06



Privacy-Preserving Telemetry

- **Differential privacy** for sensor data streams
- Prevent **re-identification** from anonymised usage
- Applies to smart home, wearables, industrial IoT

07



Regulatory Compliance

- Map **ETSI EN 303 645 / NIST IR 8259 / EU CRA**
- Formal methods for **compliance attestation**
- Verifiable audit trails on embedded systems

08



Supply Chain Security

- **Provenance tracking** of hardware components
- Detection of **malicious silicon implants**
- Verify manufactured devices match authorised design